

BEFORE Placeholder

AFTER

Policy Exceptions Standard (Third-Party Security Program)

Document classification: Internal

Document owner: Third-Party Security Program Owner

Version: 0.1

Effective date: _____

Review cadence: Every 12 months or upon material change

1. Purpose

This document defines the standard for requesting, approving, tracking, and closing exceptions to Third-Party minimum security requirements.

2. Definition

A **policy exception** is a formally approved, time-bound deviation from a **MUST** requirement in ``03-minimum-security-requirements-by-tier.md``.

An exception is required when a supplier cannot meet a MUST requirement within the required timeframe and onboarding/renewal is still proposed.

3. Principles

All exceptions MUST be:

- **Explicit:** clearly state the control requirement, the gap, and the affected scope.
- **Compensated:** include compensating controls (technical preferred).
- **Time-bound:** include an expiry date and remediation milestone(s).

- **Owned:** assign a single accountable owner for closure.
- **Auditable:** record approvals, rationale, and evidence of closure.

Default rule: if uncertainty exists, treat the deviation as requiring an exception.

4. When exceptions are permitted

Exceptions may be considered when:

- The business need is validated and alternatives are not feasible in required timelines.
- Compensating controls reduce exposure to an acceptable level.
- A credible remediation plan exists with a defined completion date.

Exceptions are not permitted where:

- The residual risk is assessed as unacceptable for the tier and service scope.
- The supplier refuses reasonable contractual incident notification commitments for Critical suppliers.
- The supplier cannot provide minimum assurance for the service scope (e.g., unwilling to answer basic due diligence questions).

5. Approval requirements

Exceptions **MUST** be approved in line with ``02-governance-approvals-escalation.md`` and include residual risk acceptance by the appropriate authority for the supplier tier.

No exception is valid without:

- documented business owner endorsement, and
- documented security approval, and
- an expiry date.

6. Exception lifecycle

1. **Identify gap:** Security reviewer confirms the unmet MUST requirement and impact.
2. **Define compensating controls:** Prefer technical controls (least privilege, segmentation, logging, brokered access).
3. **Document remediation plan:** Supplier commitment and internal actions with target dates.
4. **Approve:** obtain approvals per tier and record residual risk acceptance.
5. **Implement compensating controls:** prior to onboarding where feasible.
6. **Track to closure:** monitor progress, re-validate, and collect closure evidence.
7. **Expire/renew:** exceptions expire automatically on the expiry date unless formally renewed.

7. Compensating controls (examples)

Preferred compensating controls are technical and verifiable, such as:

- Restricting access scope/roles; removing admin rights where possible
- Enforcing SSO/MFA via conditional access or brokered authentication
- Brokered privileged access (PAM/JIT), approvals, and session recording
- Network segmentation and restricted egress/ingress rules
- API scope reduction, key rotation, and short-lived tokens
- Enhanced logging and monitoring for supplier activity
- Temporary isolation of environments (non-production only) until controls are met

Administrative compensating controls (acceptable only where technical controls are not feasible):

- Increased review cadence
- Manual access recertification
- Additional contractual commitments and reporting

8. Required fields (Exception Record)

All exceptions MUST be recorded using the following minimum fields:

8.1 Exception summary

- Exception ID: _____
- Supplier name: _____
- Service/product: _____
- Tier: ☐ Critical ☐ Important ☐ Low
- Scope (systems/data/integration): _____
- Requirement reference (document + section): _____
- Requirement statement (MUST): _____

8.2 Gap description

- Description of unmet requirement: _____
- Reason not met (e.g., product limitation, timeline, contractual constraint):

8.3 Risk statement (plain language)

- What could go wrong if we proceed: _____
- Likely impact (confidentiality/integrity/availability): _____
- Affected parties/services: _____

8.4 Compensating controls

- Compensating controls to implement (technical preferred):

- Validation method (how we will verify controls are in place):

8.5 Remediation plan

- Supplier remediation action(s): _____
- Target completion date(s): _____
- Internal action(s) required (if any): _____
- Re-validation checkpoint date: _____

8.6 Expiry

- Exception effective date: _____
- Exception expiry date: _____ Rules:
- Exceptions MUST have an expiry date.
- Expired exceptions require immediate escalation and either closure, renewal approval, or service restriction/offboarding decision.

8.7 Approvals (generic role titles)

- Security approver (role title): _____ Name/initials: _____ Date: _____
- Business Service Owner (role title): _____ Name/initials: _____ Date: _____
- Senior residual risk acceptor (role title, if required by tier): _____ Name/initials: _____ Date: _____

8.8 Closure evidence

- Closure date: _____
- Evidence of remediation and re-validation:

- Exception status: ☐ Closed ☐ Renewed (new ID) ☐ Rejected (service blocked)

9. Renewal and material change

Exceptions MUST be re-reviewed upon:

- contract renewal,

- scope change (new data types, new integrations, privileged access changes),
- supplier incident/breach,
- sub-processor changes affecting the service,
- tier change.

Renewals must reference the original exception ID and provide updated evidence and timelines.

10. Record keeping

Exception records and supporting evidence **MUST** be retained in the designated program repository/location and be accessible for audit and assurance activities.